

TrustEpisode: Calibrated Episode Risk Scoring with Evidence-Grounded Agentic RAG for Multi-Step Cyber Attacks

Anonymous Author(s)

Abstract

Multi-step cyber attacks, including advanced persistent threats (APTs) and ransomware campaigns, rarely manifest as a single decisive alert. Instead, they unfold through temporally dispersed, heterogeneous, and partially inconsistent observations across endpoint activity, network telemetry, identity events, asset context, operational technology visibility, and cyber-threat intelligence. Existing security operations commonly rely on static correlation rules that are difficult to adapt across environments, while LLM-based security agents can produce plausible but insufficiently calibrated risk assessments when evidence is incomplete, stale, or contradictory.

We present TRUSTEPISODE, a multi-layer framework for calibrated and evidence-traceable episode risk scoring over heterogeneous security telemetry. The Evidence Fabric Layer transforms observations into a temporally aligned evidence graph with provenance, reliability, freshness, and asset-context annotations. The Episode Synthesis Layer groups related observations into candidate attack episodes. The Calibrated Trust Scoring Layer computes a score from behavioral deviation, attack-stage coherence, cross-source corroboration, source reliability, evidence freshness, asset criticality, and bounded CTI alignment using a constrained learnable model. Unlike fully rule-based correlation, TRUSTEPISODE learns score calibration from observed benign and attack behavior while retaining factor-level interpretability. An Agentic Evidence Assurance Layer applies evidence-grounded retrieval to retrieve supporting and contradicting evidence, identify missing observations, and produce cited narratives; it does not directly assign the numerical score.

We evaluate TRUSTEPISODE through a three-tier empirical protocol: public DARPA Transparent Computing traces, controlled Caldera-based breach-and-attack simulations, and anonymized enterprise telemetry for external validation. We measure episode reconstruction, risk ranking, calibration, robustness to telemetry loss and misleading CTI, evidence traceability, and time to analyst-verifiable conclusions.

Keywords

multi-step attack detection, calibrated risk scoring, provenance, security telemetry, agentic RAG, cyber threat intelligence

1 Introduction

Security operations centers receive heterogeneous alerts from endpoint detection and response (EDR), network detection and response (NDR), identity systems, system logs, asset inventories, operational technology (OT) monitoring, and cyber-threat intelligence (CTI) feeds. APT and ransomware campaigns are not normally represented by one conclusive alarm. They appear as an evolving sequence of weak signals: an unusual remote connection, a suspicious script, a credential-access indicator, lateral movement, and

finally an impact precursor. Each element alone can be benign, incomplete, or too low-confidence to merit escalation.

The central operational question is therefore not only whether an event is anomalous. It is whether a set of heterogeneous observations should be assembled into one candidate attack episode, how much confidence should be assigned to that episode, and whether the resulting score is sufficiently grounded for analyst action. Static SIEM and XDR correlation commonly rely on manually tuned rule chains and severity aggregation. These mechanisms are fast and interpretable, but are brittle when behavior differs across sites, telemetry is partially missing, or normal administration resembles attacker tradecraft. At the opposite extreme, deep graph methods and LLM-based triage can improve recall or narrative quality but often weaken score calibration, repeatability, and factor-level explanation.

CAPTAIN demonstrates that a rule-oriented provenance detector can be made adaptive by learning fine-grained node, edge, and threshold parameters through differentiable tag propagation [4]. Its central insight is important: systems should retain lightweight, semantically meaningful detection mechanisms while learning deployment-specific configurations. TRUSTEPISODE extends this insight beyond host provenance into heterogeneous, episode-level operational risk scoring. We treat an attack episode as a temporal evidence subgraph spanning endpoint, network, identity, context, and CTI observations, and explicitly separate (i) episode formation, (ii) calibrated risk scoring, and (iii) evidence assurance.

This separation is especially important for Agentic RAG. CTI, historical cases, and policy documents can be valuable for investigation, but retrieved text may be stale, contradictory, irrelevant to local context, or adversarially influenced. Therefore, TRUSTEPISODE uses Agentic RAG to retrieve support, contradiction, and missing evidence, while the numerical score remains under a constrained learnable scoring model. The agent can explain and challenge a score; it cannot silently replace it.

Research question. How can a security system assign calibrated, interpretable, and evidence-traceable risk scores to multi-step attack episodes formed from heterogeneous telemetry without relying solely on fixed rules or unconstrained LLM judgment?

Contributions. This paper makes four contributions:

- (1) We introduce TRUSTEPISODE, a multi-layer framework that converts heterogeneous security telemetry into prioritized, evidence-traceable attack episodes.
- (2) We propose a constrained learnable episode scorer that combines behavioral deviation, temporal and causal coherence, cross-source corroboration, evidence quality, asset impact, and bounded CTI alignment.
- (3) We define an Agentic Evidence Assurance Layer that retrieves supporting, contradicting, and missing evidence without directly controlling numerical risk scores.

- (4) We specify a three-tier evaluation protocol using public provenance-rich traces, controlled Caldera BAS scenarios, and anonymized enterprise validation.

2 Related Work

2.1 Provenance and Graph-Based Intrusion Detection

Provenance-based intrusion detection systems (PIDS) construct causal graphs in which nodes represent system entities and edges capture information-flow or execution relations. This structure is effective for reconstructing attack paths and preserving causal context. Existing methods range from graph embeddings and neural detectors to rule-based propagation and graph matching. CAPTAIN positions itself in the latter family, adapting rule-based PIDS by optimizing node initialization, edge propagation, and alarm thresholds while retaining low overhead and interpretability [4]. However, many provenance detectors remain host-centric and issue alarms at the node, edge, or subgraph level. They do not directly produce calibrated, cross-source, episode-level operational risk scores.

2.2 Adaptive Correlation and Risk-Based Security Operations

Alert aggregation, SIEM correlation, attack-path prioritization, and XDR risk scoring aim to reduce analyst load. Yet alert counts and vendor severity labels are not synonymous with operational risk. A high-confidence indicator match can be irrelevant to the affected asset; conversely, several low-severity events can become significant when they form a coherent sequence. TRUSTEPISODEtherefore models risk at the episode level and separates maliciousness likelihood from operational impact. The model learns locally appropriate contributions while preserving explicit semantic factors and policy constraints.

2.3 CTI, Retrieval-Augmented Analysis, and Security Agents

CTI can enrich detection through indicators, technique mappings, and adversary context, but intelligence is heterogeneous in freshness and reliability. Retrieval-augmented generation (RAG) improves the grounding of language-model outputs by augmenting generation with retrieved evidence [3]. In a security setting, however, direct LLM scoring can lead to uncalibrated risk judgments and overly confident explanations. TRUSTEPISODEtreats CTI as a bounded, corroborative input and uses Agentic RAG only for assurance: evidence retrieval, contradiction discovery, gap identification, and citation-aware reporting. The agent is read-only with respect to the primary score and enforcement actions.

2.4 Calibration, Robustness, and Explanation

Risk ranking and risk calibration solve different problems. A model can rank malicious episodes near the top while systematically overestimating or underestimating their probability. This distinction matters when a score determines escalation thresholds, analyst attention, and the amount of evidence demanded before a potentially disruptive response. TRUSTEPISODEtherefore uses calibration loss

and reliability analysis as first-class evaluation targets rather than treating an anomaly value as a probability by default.

Robustness is similarly distinct from raw classification performance. In real operations, a network sensor may be absent, identity events may arrive late, asset inventory may be stale, and CTI may contain weak or contradictory indicators. We design the model so that absence of evidence reduces confidence through an explicit penalty rather than silently increasing the likelihood of a threat. The final score can therefore be accompanied by a caveat such as “high priority, but reduced confidence because NDR corroboration is unavailable.” This is a more actionable output than a single opaque anomaly score.

3 TrustEpisode Method

3.1 Overview and Threat Model

TRUSTEPISODEreceives telemetry streams from EDR, NDR, Syslog, identity logs, OT/ICS visibility, asset/CMDB sources, and CTI. It outputs candidate episodes, a calibrated likelihood, an operational-priority score, a factor-level score trace, and an analyst-facing cited narrative. Figure 1 presents the architecture.

We assume that monitored collectors and transport are trusted for the scope of this work, as in common PIDS assumptions [4]. Attackers may execute APT or ransomware precursor behavior, use living-off-the-land techniques, create low-signal activity, exploit delayed telemetry, and benefit from stale or misleading CTI. We do not address attacks that leave no relevant observable trace in the monitored environment.

3.2 Evidence Fabric Layer

Each raw event is normalized into $e = (t, s, u, v, a, x, q, p)$, where t is timestamp, s is telemetry source, u and v are subject and object entities, a is an action, x is associated attributes, q is collection confidence, and p is provenance that links to raw evidence. The Evidence Fabric Layer constructs a temporal evidence graph $G = (V, E)$, where nodes represent processes, hosts, users, files, IP addresses, services, assets, CTI objects, and contextual objects. Edges represent causal, temporal, communication, identity, containment, and semantic relations.

Evidence objects retain source reliability, freshness, completeness, asset context, and corroborating-source count. CTI objects additionally retain publication time, source confidence, technique mapping, and relevance metadata. This representation is deliberately broader than a host-only provenance graph: a process execution can be linked to a device identity, an external destination, an asset criticality label, and CTI context without treating any one source as conclusive.

3.3 Episode Synthesis Layer

A candidate episode $\epsilon = (V_\epsilon, E_\epsilon, t_0, t_1, A_\epsilon)$ is a temporally bounded evidence subgraph with affected asset set A_ϵ . TRUSTEPISODEjoins events or subgraphs using an episode-linking function:

$$L(e_i, e_j) = \alpha_T T_{ij} + \alpha_C C_{ij} + \alpha_E E_{ij} + \alpha_S S_{ij} + \alpha_M M_{ij} + \alpha_X X_{ij}, \quad (1)$$

where T_{ij} measures temporal proximity, C_{ij} causal relation, E_{ij} entity continuity, S_{ij} shared asset context, M_{ij} coarse ATT&CK-stage

Table 1: Positioning of TRUSTEPISODE relative to representative approach families.

Capability	Static correlation	PIDS / graph detection	LLM/RAG triage	CAPTAIN	TRUSTEPISODE
Heterogeneous telemetry fusion	Partial	Usually host-centric	Possible	Host provenance	Yes
Episode-level risk score	Limited	Partial	Informal	Edge / alarm-focused	Yes
Explicit probability calibration	Rare	Partial	No guarantee	Adaptive thresholds	Yes
Bounded CTI contribution	Rare	Rare	Often unclear	N/A	Yes
Factor-level score audit	Limited	Limited	Limited	Strong	Strong
Agentic evidence assurance	No	No	Yes	No	Yes
Agent directly assigns score	No	No	Often	No	No

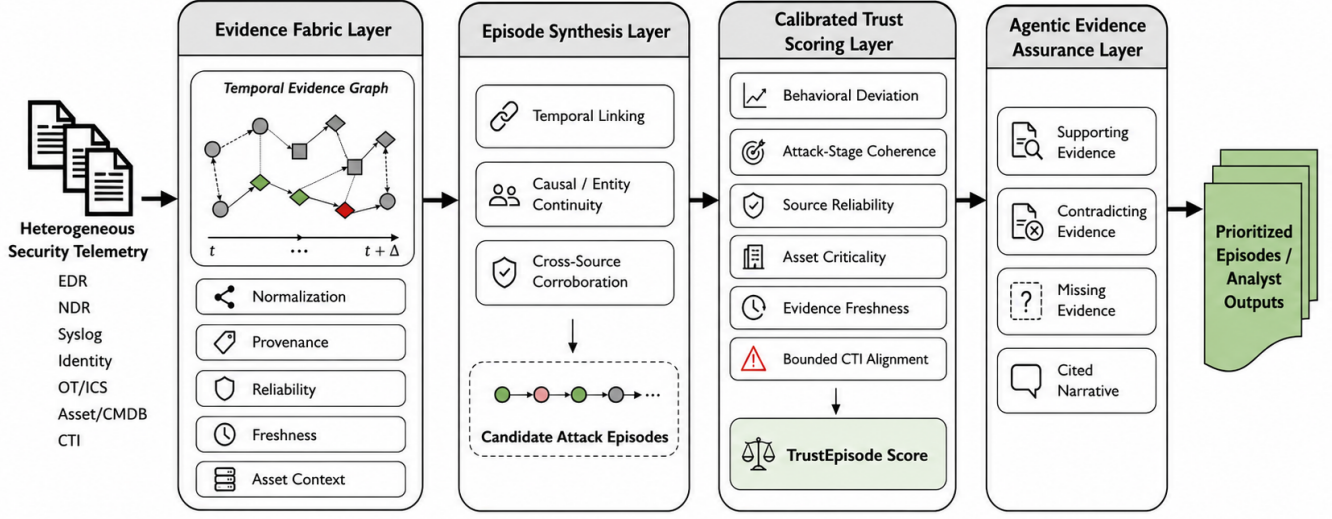


Figure 1: A brief overview of the workflow and major components of TRUSTEPISODE. The four layers preserve the separation between evidence representation, episode formation, calibrated scoring, and agentic assurance.

coherence, and X_{ij} cross-source corroboration. Events are merged when L exceeds a context-aware threshold. Episodes may progress through *emerging*, *corroborating*, *high-risk*, *under investigation*, and *resolved* or *escalated* states. This lifecycle allows later contradictory evidence to reduce confidence rather than forcing every episode into a fixed attack chain.

3.4 Feature Semantics and Constraint Design

The feature design intentionally separates evidence strength from evidence impact. Behavioral deviation D_e is computed against a local baseline for entities, services, or communication patterns rather than a global frequency alone. Attack-stage coherence K_e measures whether observed actions form a temporally and causally plausible progression, while allowing missing or reordered stages. Cross-source corroboration C_e rewards independent agreement among endpoint, network, identity, and context sources, avoiding double-counting multiple alerts generated by the same upstream event.

Evidence quality Q_e aggregates collection reliability, parsing confidence, and temporal freshness. Operational impact A_e incorporates asset criticality, exposure, affected-user scope, and segment sensitivity, but cannot independently turn benign maintenance activity into a high-risk episode. CTI alignment T_e is a semantic

and indicator-level comparison between observed evidence and curated intelligence. Its contribution is bounded because a match to a stale or generic report should not override stronger local evidence. Finally, M_e captures missing evidence, such as an absent expected network observation after a suspicious execution event. This penalty expresses uncertainty rather than treating absence as proof of benignness.

The model imposes monotonic and bounded constraints derived from security semantics. For example, increased independent corroboration must not decrease the likelihood score; lower source reliability must not increase confidence; and the contribution of CTI must remain within a predefined range. These constraints preserve interpretability and prevent the learned model from converging to spurious, difficult-to-review configurations.

3.5 Calibrated Trust Scoring Layer

The scorer separates maliciousness likelihood P_e from operational impact I_e . The final operational priority is $R_e = P_e \times I_e$. For each episode, it computes behavioral deviation D_e , temporal and causal coherence K_e , corroboration C_e , evidence quality Q_e , asset impact A_e , bounded CTI alignment T_e , and missing-evidence penalty M_e .

The uncalibrated score is:

$$z_\epsilon = f_D(D_\epsilon) + f_K(K_\epsilon) + f_C(C_\epsilon) + f_Q(Q_\epsilon) + f_A(A_\epsilon) + \text{clip}(f_T(T_\epsilon), -\kappa, \kappa) - f_M(M_\epsilon) - f_H(H_\epsilon) \quad (2)$$

where each f is constrained to preserve interpretable monotonic behavior. For example, stronger corroboration cannot decrease risk, missing evidence cannot increase confidence, and CTI influence cannot exceed a bound κ . A calibration function produces $P_\epsilon = \text{Calibrate}(\sigma(z_\epsilon))$.

The model is not a static rule chain such as “suspicious process AND external IP implies high risk.” It learns factor contributions and calibration from benign and attack behavior while retaining semantic constraints. The learning objective combines classification, calibration, stability, regularization, and CTI-bound terms:

$$\mathcal{L} = \mathcal{L}_{\text{cls}} + \lambda_1 \mathcal{L}_{\text{cal}} + \lambda_2 \mathcal{L}_{\text{stab}} + \lambda_3 \mathcal{L}_{\text{reg}} + \lambda_4 \mathcal{L}_{\text{CTI}}. \quad (3)$$

For every score, the system preserves contributing events, feature values, contribution values, source reliability, CTI contribution, calibration version, and counterfactual score changes. Analysts can ask how a score changes when CTI is removed, NDR telemetry is unavailable, or an asset is not critical.

3.6 Learning, Calibration, and Online Operation

Training is organized in two stages. First, the Evidence Fabric Layer estimates baselines from benign or analyst-approved windows. Second, the scoring parameters are optimized from labeled attack episodes when available, or from calibrated negative feedback and controlled BAS traces when attack labels are limited. We use temporally separated train, validation, and test periods so that closely adjacent events do not leak into both calibration and evaluation sets. Hyperparameters, including the CTI bound κ , are selected on validation data and fixed before test evaluation.

At runtime, the pipeline processes normalized events incrementally. It updates the temporal graph, re-evaluates affected candidate episodes, and emits a score only when the episode state changes materially or a configured decision boundary is crossed. Baseline updates are gated: benign feedback must satisfy source-quality and analyst-review conditions before it can influence the local model. This design reduces the risk that a single burst of anomalous activity or attacker-driven poisoning changes the normality model. Each deployed scorer is versioned, enabling analysts to determine which calibration model produced a historical score.

3.7 Trace-Transparent Risk Computation

A `TrustEpisode` record is an auditable object, not merely a number. It contains the episode graph, source event identifiers, feature values, calibrated likelihood, operational impact, factor contributions, data-quality caveats, CTI items used, model version, and counterfactual scores. The counterfactual interface replays a score after removing one category of evidence, changing asset criticality, or discounting stale CTI. This supports both analyst investigation and post-incident review: a reviewer can distinguish “high risk because of independent endpoint and identity corroboration” from “high risk largely because of a weak CTI match.”

3.8 Agentic Evidence Assurance Layer

The Agentic Evidence Assurance Layer does not calculate P_ϵ , I_ϵ , or M_ϵ . Instead, it retrieves (i) evidence supporting a high-risk episode, (ii) evidence contradicting the episode hypothesis, (iii) missing telemetry or context, and (iv) relevant CTI, policy, and historical incident records. It then generates a cited narrative with score caveats and a recommended analyst next step.

Retrieval is source-aware and restricted to the episode-graph neighborhood, raw telemetry provenance, curated CTI, asset/service inventory, historical incident records, detection policies, and controlled validation records. The agent uses read-only investigation tools, requires citations for factual claims, and must emit an *insufficient evidence* state when the available record cannot justify a conclusion. It cannot directly modify the primary score or autonomously enforce a destructive response. Figure 3 illustrates this separation.

Two-sided retrieval. For each high-risk episode, the agent executes a support-and-challenge loop. It first retrieves the evidence objects that contributed to the score, then seeks alternative explanations such as known maintenance windows, approved remote-management systems, asset ownership information, or benign historical patterns. A narrative is accepted only when it distinguishes direct observation from inferred context and cites the provenance of each material claim.

Evidence gates and human oversight. The assurance layer marks an episode as evidence-sufficient only when required source categories and citation checks are satisfied. When high-priority evidence is contradictory or incomplete, the output is a confidence caveat and an analyst task, not an autonomous enforcement decision. This boundary is essential for environments in which blocking or isolating an asset can have business, safety, or clinical consequences.

4 Evaluation

4.1 Research Questions

We evaluate five questions: **RQ1** Can the method reconstruct multi-step episodes from heterogeneous evidence? **RQ2** Does it improve risk ranking and calibration relative to static correlation, graph-oriented baselines, and direct LLM/RAG triage? **RQ3** Does performance degrade gracefully under telemetry loss, benign operational drift, and misleading CTI? **RQ4** Can it provide analyst-verifiable evidence traces? **RQ5** Is the system operationally feasible in realistic telemetry conditions?

4.2 Three-Tier Experimental Setting

Tier 1: Public provenance-rich traces. We use selected DARPA Transparent Computing (TC) engagement traces to support reproducible multi-step attack analysis. The TC program provides public materials for provenance-oriented security research [2]. These traces are appropriate for evaluating temporal and causal episode formation, but they are not equivalent to long-lived production enterprise telemetry. Attack reports and scenario labels are used only as ground truth; they are excluded from the RAG corpus to avoid label leakage.

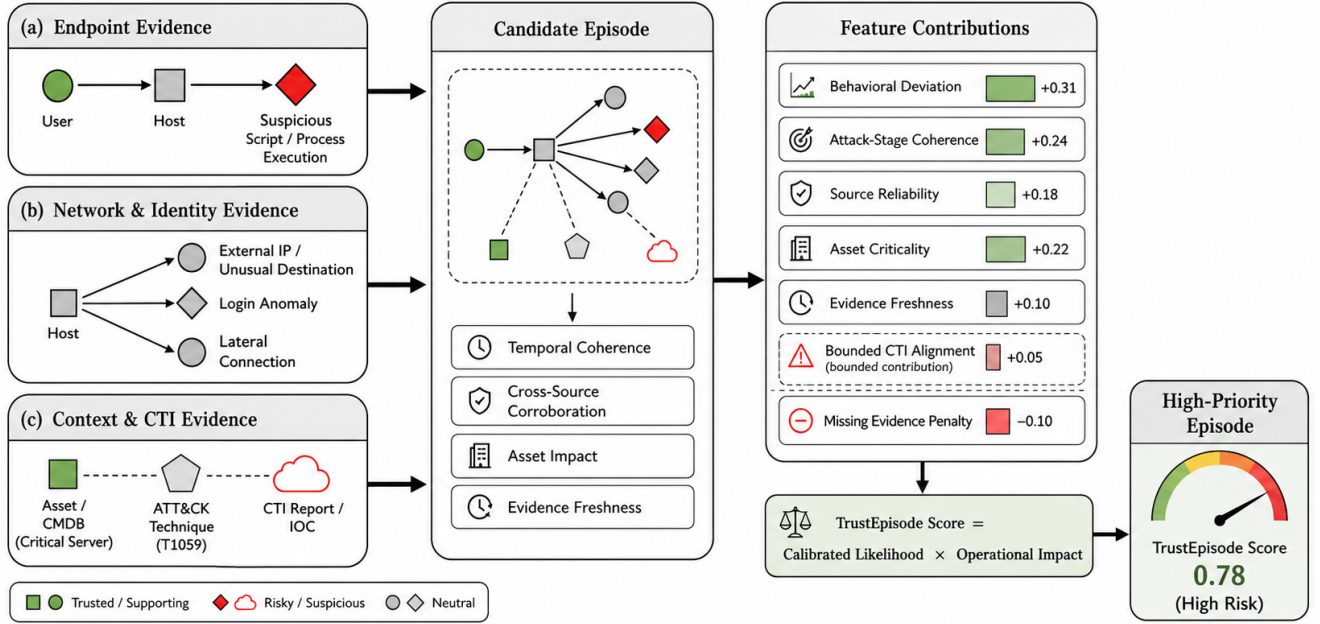


Figure 2: An example candidate episode and its interpretable score contributions. CTI is present as contextual evidence but its contribution is explicitly bounded.

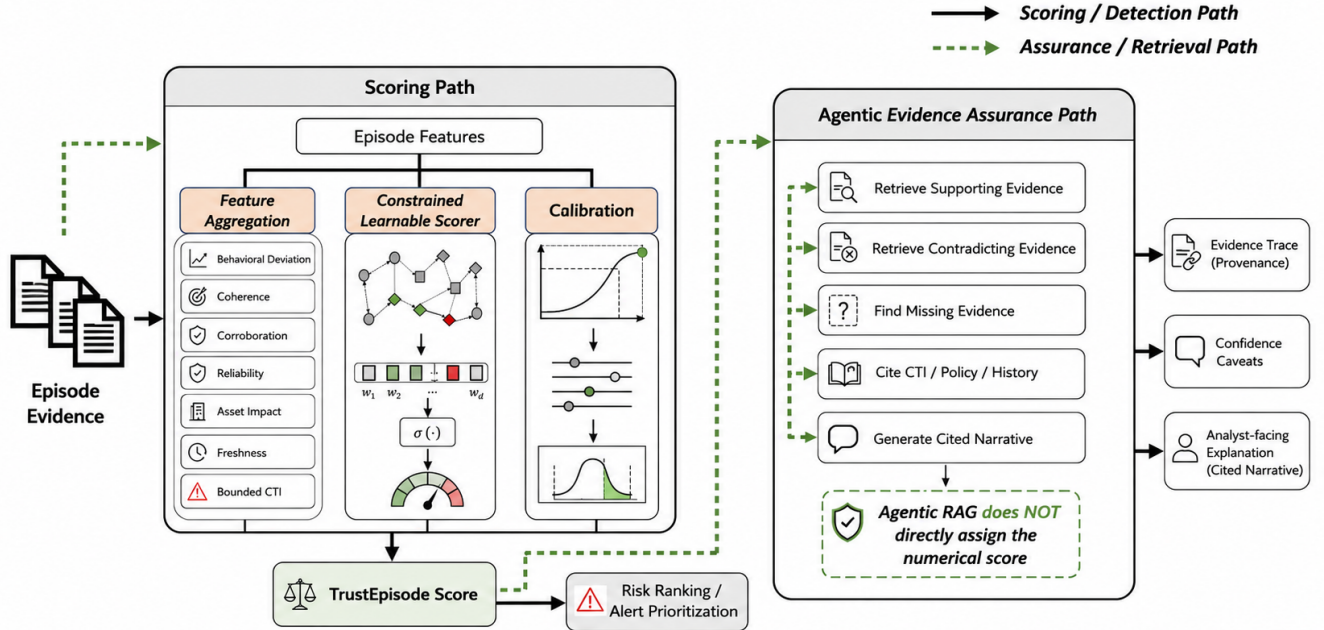


Figure 3: TRUSTEPISODE separates calibrated scoring from agentic evidence assurance. Solid arrows are the scoring path; dashed green arrows indicate retrieval and assurance loops.

Tier 2: Controlled Caldera BAS. We construct an isolated laboratory with a Caldera control node, Linux and Windows endpoints, EDR and NDR collection, central logging, identity observations, asset inventory, curated CTI, and the TRUSTEPISODE scoring service. Caldera is an ATT&CK-aligned automated adversary-emulation

platform [1]. Scenario families include non-destructive APT-style chains (execution, discovery, credential-access simulation, lateral movement, collection simulation, and C2 emulation) and ransomware precursor chains (remote-administration misuse, discovery, credential-access simulation, lateral movement, share/backup discovery, and

impact markers). We vary telemetry loss, event delay, benign administrative drift, CTI freshness, CTI conflict, attack order, and inter-step timing.

Tier 3: Enterprise external validation. We deploy a prototype on anonymized enterprise telemetry and evaluate high-priority episode quality, analyst agreement, alert reduction, time to meaningful triage, evidence trace completeness, and operational overhead. We do not claim complete attack ground truth in this tier. Host identifiers are pseudonymized, user identifiers are hashed, IP addresses are tokenized or redacted, and organization-specific metadata is removed.

4.3 System Implementation and Laboratory Context

The prototype consists of a normalization service, temporal evidence-graph store, episode-linking engine, calibrated scoring service, retrieval index, and analyst-facing case interface. The normalization service consumes source-native events and maps them into a common schema. The graph store maintains entity and relation state over a configurable horizon; the scoring service maintains episode state and contribution traces; the retrieval index stores curated CTI, policy records, and historical investigation material with source and freshness metadata.

The controlled laboratory is intentionally segmented. A Caldera control node orchestrates emulation activities against designated Windows and Linux targets. EDR, network telemetry, Syslog, identity observations, and asset labels are routed to the collection layer. The testing scenarios are non-destructive: they use discovery, process execution, credential-access simulation, lateral movement, and impact markers rather than destructive encryption or production service disruption. This environment provides a repeatable setting to vary one factor at a time while holding collection and scoring configurations constant.

4.4 Ablation and Robustness Protocol

We evaluate the contribution of each design choice by comparing the full model with variants that remove CTI, remove cross-source corroboration, disable the calibration objective, permit unbounded CTI, replace learnable contributions with fixed thresholds, or omit Agentic Evidence Assurance. CTI robustness is evaluated under no-CTI, valid contextual CTI, stale CTI, conflicting CTI, and misleading CTI conditions. Telemetry robustness is evaluated by withholding one source class, delaying identity events, dropping a fraction of network records, and introducing benign operational drift such as approved maintenance scripts and periodic administrative scans.

A robust model should degrade gracefully rather than become overconfident. We therefore report both discriminative performance and calibration under each perturbation. Counterfactual stability measures the change in score when weak evidence is removed: a score supported by independent endpoint, network, and identity observations should not collapse when a single low-quality CTI object is discounted. Conversely, a score dominated by CTI should show a visible, reviewable reduction when that input is removed.

4.5 Analyst Review Protocol

For selected Tier 3 episodes, analysts first review a normalized episode timeline without the model’s rank. They then review the TrustEpisode score trace and cited narrative. We record agreement on priority, perceived sufficiency of evidence, false-positive ratio-nale, and time to reach a defensible next step. This protocol evaluates whether explanations change analysts’ decisions constructively rather than merely making a system appear persuasive. Any analyst feedback used for recalibration is logged separately from held-out evaluation decisions.

4.6 Baselines and Metrics

We compare TRUSTEPISODE against (B1) static severity aggregation, (B2) fixed rule-based correlation, (B3) frequency or anomaly-based provenance scoring, (B4) an adaptive provenance baseline inspired by CAPTAIN, and (B5) direct LLM/RAG triage. Baselines are configured to consume compatible inputs where possible and are evaluated under identical episode windows.

Episode reconstruction is measured by episode precision, recall, F1, attack-path coverage, and time-to-episode detection. Risk ranking is measured by AUPRC, AUROC, NDCG@10, Precision@K, and mean reciprocal rank. Since SOC data are strongly imbalanced, AUPRC and NDCG@10 are primary ranking measures. Calibration is measured by expected calibration error (ECE), Brier score, negative log-likelihood, and reliability diagrams. Robustness measures include performance degradation under telemetry loss, calibration degradation under CTI perturbation, and score variance under benign drift. Evidence assurance is measured through citation-support precision, unsupported-claim rate, contradiction-retrieval recall, missing-evidence identification rate, and evidence-trace completeness. Operational metrics include events per second, end-to-end scoring latency, memory usage, agentic-investigation latency, and analyst time-to-grounded conclusion.

4.7 Results Table and Reporting Plan

Table 3 is the final reporting layout. Values are intentionally marked as pending because this submission draft does not fabricate experimental outcomes. The completed paper will report means and confidence intervals over scenario seeds, time windows, or analyst-review samples as appropriate. We will additionally include calibration plots, an ablation of bounded CTI alignment, and two compact case studies: one APT-style lateral-movement episode and one false positive reduced by contradictory maintenance-window evidence.

4.8 Planned Result Analysis

The completed results section will use three complementary views. First, a main comparison table will report episode F1, ranking metrics, calibration, trace completeness, and latency. Second, reliability diagrams will show whether predicted likelihood tracks empirical attack frequency. Third, robustness plots will compare the full model and ablations across telemetry-loss and CTI-perturbation conditions. We will avoid claiming superiority from a single aggregate score; results must be consistent across ranking, calibration, and traceability measures.

Two case studies will accompany the quantitative results. The first will reconstruct an APT-style lateral-movement episode from

Table 2: Three-tier empirical evaluation design.

Tier	Data / context	Ground truth	Primary purpose
Tier 1	DARPA TC provenance-rich adversarial traces	Attack reports, scenario intervals, and labels	Reproducible evaluation of episode linking, causal coherence, and calibration.
Tier 2	Isolated Caldera BAS laboratory with EDR, NDR, Syslog, identity, asset, and CTI inputs	Scenario and ATT&CK-aligned technique labels	Controlled robustness tests under missing telemetry, benign drift, stale/conflicting CTI, and attack variations.
Tier 3	Anonymized enterprise telemetry and analyst review	Analyst adjudication and operational case review	External validity, analyst utility, and deployment overhead.

Table 3: Main result table template. Replace pending entries only with measured values from the three-tier evaluation. Arrows indicate preferred direction.

Method	Episode F1 ↑	AUPRC ↑	NDCG@10 ↑	ECE ↓	Brier ↓	Trace Comp. ↑	Latency ↓
Static severity aggregation	—	—	—	—	—	—	—
Fixed rule correlation	—	—	—	—	—	—	—
Provenance anomaly baseline	—	—	—	—	—	—	—
Adaptive provenance baseline	—	—	—	—	—	—	—
Direct LLM/RAG triage	—	—	—	—	—	—	—
TRUSTEPISODE	—	—	—	—	—	—	—

low-severity endpoint execution, identity anomalies, cross-host movement, and contextual CTI. The second will demonstrate a false-positive reduction: a suspicious script on a critical asset is discounted after the assurance layer retrieves an approved maintenance window, authorized administrative identity, and known management server. These paired cases illustrate both escalation and de-escalation behavior.

4.9 Discussion

Beyond adaptive provenance detection. TRUSTEPISODE adopts CAPTAIN’s adaptation principle but changes the target of learning. Rather than learning configuration for a host-provenance alarm, it learns calibrated episode-level risk from heterogeneous sources, separates likelihood from impact, constrains CTI influence, and records an auditable evidence trace.

Why Agentic RAG does not score. An LLM can help discover context and explain a decision, but its output is probabilistic and can vary with retrieval content. Allowing an agent to determine the primary score would complicate calibration, reproducibility, and safety review. The assurance layer instead verifies, challenges, cites, and identifies gaps in the factors used by the scorer.

Limitations. Public provenance traces do not capture all modern enterprise networks; Caldera emulation cannot represent every evasion behavior; and enterprise validation may not provide complete attack labels. Asset criticality and CTI quality can also be incomplete. Secure online adaptation and poisoning-resilient drift management remain future work.

Safety and ethics. All BAS experiments are isolated and non-destructive. No production-impacting ransomware encryption or disruptive OT operation is executed. Enterprise telemetry is anonymized and access controlled. Agentic tools are read-only and cannot autonomously modify enforcement controls.

5 Conclusion

We presented TRUSTEPISODE, a multi-layer method for calibrated episode risk scoring over heterogeneous security telemetry. The system combines an Evidence Fabric Layer, Episode Synthesis Layer, Calibrated Trust Scoring Layer, and Agentic Evidence Assurance Layer. Its central contribution is a constrained, learnable, and auditable score that combines behavioral deviation, attack coherence, corroboration, evidence quality, asset context, and bounded CTI alignment.

Unlike static correlation, TRUSTEPISODE adapts score contributions to observed behavior. Unlike unconstrained LLM triage, its numerical outputs remain calibrated, reproducible, and traceable to evidence. The proposed three-tier evaluation unifies public provenance traces, controlled BAS validation, and enterprise external validation to assess reconstruction, ranking, calibration, robustness, and operational utility.

References

- [1] Apache Software Foundation. 2026. MITRE Caldera: Automated Adversary Emulation Platform. GitHub repository. Accessed: 2026-06-28. <https://github.com/apache/caldera>
- [2] DARPA Information Innovation Office. 2026. Transparent Computing Program Materials. GitHub repository. Accessed: 2026-06-28. <https://github.com/darpa-i2o/Transparent-Computing>
- [3] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Kuttler, Mike Lewis, Wen tau Yih, Tim Rocktaschel, Sebastian Riedel, and Douwe Kiela. 2020. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. In *Advances in Neural Information Processing Systems*, Vol. 33.
- [4] Lingzhi Wang, Xiangmin Shen, Weijian Li, Zhenyuan Li, R. Sekar, Han Liu, and Yan Chen. 2025. Incorporating Gradients to Rules: Towards Lightweight, Adaptive Provenance-based Intrusion Detection. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. doi:10.14722/ndss.2025.230822